

Human Compass MSO

COMP 03	
HIPAA Program	
Lines of Business: ALL (MEDICARE, MEDI-CAL, COMMERCIAL)	
Original Effective Date: 01.01.2026	Written By: Linette Hughes
Date of Last Revision:	Revised By:
Date of Last Review: 09.23.2026	Reviewed By: Linette Hughes
Date of Last Approval: 08.27.2025	Approved By: Board of Directors

I. Purpose

1. To accept and comply with a common set of general provisions and definitions related to HIPAA and ARRA guidelines.
2. To identify and apply: (a) any HIPAA pre-emption requirements to State law; and (b) any State law that is more stringent than the requirements of HIPAA.
3. To establish Human Compass MSO Compliance and Enforcement procedures, based upon HIPAA and ARRA Standards and Implementation Specifications.

II. Scope

The HIPAA Program, which falls under the auspices of Compliance, applies to:

1. All Human Compass MSO team members, Governing Board Members, Management, and Contracted Entities
2. Every Healthcare Provider, regardless of size, who holds or transmits member protected health information (PHI) in any form
3. Human Compass MSO business associates, first tier and downstream entities and vendors that perform certain functions or activities on behalf of Human Compass MSO that involve the use or disclosure of member identifiable health information.

III. Definitions

1. Access and Uses: For internal uses, Human Compass MSO allows Team Member access to PHI subject to qualifying job requirements. Each Team Member is provided appropriate levels of security with the minimum necessary to perform their job duties.
2. Authorization: Human Compass MSO must obtain the Member's written authorization for any use or disclosure of PHI that is not for treatment, payment, health care operations or otherwise permitted or required by regulations and/or statutes. Authorizations must be written in specific terms; must be in plain language; and must contain specific information regarding the information to be disclosed or used, the person(s) disclosing and receiving the information, expiration, right to revoke in writing, and other data in accordance with the requirements of HIPAA (45 C.F.R. § 164.508) and California Confidentiality of Medical Information Act (Civil Code § 56.11). In most cases, parents can exercise individual rights, such as access to the medical record on behalf of their minor children. However, there are circumstances under which the parent is not considered the personal representative. In these situations, Human Compass MSO

Human Compass MSO

will defer to California State law to determine the rights of parents to access and control the PHI of their minor children.

3. Breach: The term “breach” has the meaning given such term in 45 C.F.R. § 164.402.
 - a. Definition: “Breach” means the acquisition, access, use, or disclosure of Protected Health Information (PHI) in a manner not permitted under 45 C.F.R. Part 164, Subpart E (“Privacy Rule”) which compromises the security or privacy of the PHI. An impermissible use or disclosure of PHI is presumed to be a breach unless the covered entity can demonstrate that there is low probability that the PHI has been compromised. For purpose of this definition, compromises the security or privacy of the PHI means poses a significant risk of financial, reputational, or other harm to the individual. A use or disclosure of PHI that does not include the identifiers listed at 45 C.F.R. § 164.514(e) (2), date of birth, and zip code does not compromise the security or privacy of the PHI.
 1. The nature and extent of PHI involved (including the types of identifiers and the likelihood of re-identification).
 2. The unauthorized person who used the PHI or to whom the disclosure was made.
 3. Whether the PHI was actually acquired and/or viewed
 4. The extent to which the risk to the PHI has been mitigated
 - b. Exceptions – Breach Excludes:
 1. Any unintentional acquisition, access, or use of protected health information by a workforce member or person acting under the authority of a covered entity or business associate if such acquisition, access, or use was made in good faith and within the scope of authority and does not result in further use or disclosure in a manner not permitted under the Privacy Rule.
 2. Any inadvertent disclosure by a person who is authorized to access protected health information at a covered entity or business associate to another person authorized to access protected health information at the same covered entity or business associate, or organized health care arrangement in which the covered entity participates, and the information received as a result of such disclosure is not further used, or disclosed in a manner not permitted under the Privacy Rule.
 3. A disclosure of protected health information where the covered entity or business associate has a good faith belief that an unauthorized person to whom the disclosure was made would not reasonably have been able to retain such information. (A covered entity may be a business associate of another covered entity).
 4. If the acquisition, access, use or disclosure of protected health information is excluded from the definition of “breach” under paragraph 3.b. above, the reporting requirements of DHCS, and / or CMS do not apply.

Human Compass MSO

4. Business Associate: The term “business associate” has the meaning given such term in Title 45, C.F.R. § 160.103.
 - a. Except as provided in paragraph 4(b) of this definition, business associate means, with respect to a covered entity, a person who:
 1. On behalf of such covered entity or of an organized health care arrangement in which the covered entity participates, but other than in the capacity of a member of the workforce of such covered entity or arrangement, performs, or assists in the performance of:
 - a. A function or activity involving the use or disclosure of individually identifiable health information, including claims processing or administration, data analysis, processing or administration, utilization review, quality assurance, billing, benefit management, practice management, and re-pricing
 - b. Any other function or activity regulated by this subchapter
 2. Provides, other than in the capacity of a member of the workforce of such covered entity, legal, actuarial, accounting, consulting, data aggregation, management, administrative, accreditation, or financial services to or for such covered entity, or to or for an organized health care arrangement in which the covered entity participates, where the provision of the services involves the disclosure of individually identifiable health information from such covered entity or arrangement, or from another business associate of such covered entity or arrangement, to the person
 - b. A covered entity participating in an organized health care arrangement that performs a function or activity as described by paragraph 4(a)(1) of this definition for or on behalf of such organized health care arrangement, or that provides a service as described in paragraph 4(2) of this definition to or for such organized health care arrangement, does not, simply through the performance of such function or activity or the provision of such service, become a business associate of other covered entities participating in such organized health care arrangement.
 - c. A covered entity may be a business associate of another covered entity.
5. Confidentiality: Relates to the obligation of the holder of personal information to protect an individual’s privacy. This obligation is determined by common practice, and federal and state laws and regulations
6. Covered Entity: The term “covered entity” has the meaning given such term in 45 C.F.R. § 160.103.
 - a. A health plan
 - b. A clearing house
 - c. A health care provider who transmits any health information in electronic form in connection with a transaction covered by this subchapter, e.g., HIPAA Administrative Data Standards and Related Requirements.

Human Compass MSO

7. Disclosure: The release, transfer, provision of, access to, or divulging in any other manner of information outside the entity holding the information (45 C.F.R. § 160.103).
8. Downstream Entity: is any party that enters a written arrangement, acceptable to CMS, with persons or entities involved with the MA benefit or Part D benefit, below the level of the arrangement between an MAO or applicant or a Part D plan sponsor or applicant and a first- tier entity. These written arrangements continue down to the level of the ultimate provider of both health and administrative services. (See, 42 C.F.R. §, 423.501).
9. Electronic Health Record (EHR): An electronic record of health-related information on an individual that is created, gathered, managed, and consulted by authorized health care clinicians and staff (42 U.S.C. § 17921(5)).
10. First Tier Entity: is any party that enters a written arrangement, acceptable to CMS, with an MAO or Part D Plan sponsor or applicant to provide administrative services or health care services to a Medicare eligible individual under the MA program or Part D program. (See, 42 C.F.R. §,423.501).
11. Vendors/Contractors: Includes all contracted Providers and suppliers, first tier entities, downstream entities and any other entities involved in the delivery of payment for or monitoring of benefits.
12. Healthcare Individuals: An individual physician or other health care professional, a hospital, a provider-sponsored organization, a health maintenance organization, a health insurance plan, or any other kind of health care facility, organization, or plan.
13. Healthcare Operations: Includes activities of the covered entity to the extent that the activities are related to covered functions:
 - a. Quality assessment and improvement activities, including outcomes evaluation and development of clinical guidelines, provided that the obtaining of generalizable knowledge is not the primary purpose of any studies resulting from such activities; population-based activities relating to improving health or reducing health care costs, protocol development, case management and care coordination, contacting of health care providers and patients with information about treatment alternatives; and related functions that do not include treatment.
 - b. Reviewing the competence or qualifications of health care professionals, evaluating practitioner/provider performance, health plan performance, conducting training programs under supervision to practice or improve health care provider skills, training of non-health care professionals, accreditation, certification, licensing, or credentialing activities.
 - c. Conducting or arranging for medical review, legal services and auditing functions, including fraud and abuse detection and compliance programs.
 - d. Business planning and development including formulary development and administration, development, or improvement of methods of payment or coverage policies.

Human Compass MSO

- e. Business management and general administrative activities of the entity as outlined in 45 C.F.R. §164.501.
- 14. Health Care Provider: A provider of medical or health services; pursuant to Title 42 United States Code (U.S.C.) Section 1395x subsections (s) and (u); and, any other person or organization who furnishes, bills, or is paid for health care in the normal course of business. (45 C.F.R. §160.103).
- 15. Health Plan: An individual or group plan that provides, or pays the cost of, medical care as defined in Title 42 U.S.C. §300gg-91(a)(2) (45 C.F.R. §160.103)
- 16. Individual: The person who is the subject of the protected health information (45 C.F.R. § 160.103).
- 17. Individually Identifiable Information: Is Information that is a subset of health information, including demographic information collected from an individual, and:
 - a. Is created or received by a health care provider, health plan, employer, or health care clearinghouse
 - b. Relates to the past, present, or future physical or mental health or condition of an individual; the provision of health care to an individual; or the past, present, or future payment for the provision of health care to an individual
 - 1. That identifies the individual or,
 - 2. With respect to which there is a reasonable basis to believe the information can be used to identify the individual
- 18. Payment: Has the meaning given such term in 45 C.F.R. §164.501
- 19. Personal Health Record (PHR): An electronic record of PHR identifiable health information (as defined in section 42 U.S.C. § 17921(11)) on an individual that can be drawn from multiple sources and that is managed, shared and controlled by or primarily for the individual.
- 20. Personal Representative: A person legally authorized to make health care decisions on a Member's behalf or to act for a deceased Member or the estate. The Privacy Rule permits an exception should Human Compass MSO have a reasonable belief that the personal representative may be abusing or neglecting the Member, or that treating the person as the personal representative could otherwise endanger the Member.
- 21. PHI Identifiable Health Information: Individually identifiable health information, as defined in section 1171(6) of the Social Security Act (42 U.S.C. 1320d(6)), and includes, with respect to an individual, information that is provided by or on behalf of the individual; and that identifies the individual or with respect to which there is a reasonable basis to believe that the information can be used to identify the individual.
- 22. Privacy: Relates to an individual's desire to control access to their personal information.
- 23. Protected Health Information (PHI): All individually identifiable health information, whether oral or recorded in any form, that relates to the physical or mental health of a Member, the provision of health care to that Member, or the payment for the provision of health care services to an individual (45 C.F.R. § 160.103).

Human Compass MSO

- a. PHI excludes individually identifiable health information in education records covered by the Family Educational Rights and Privacy Act, as amended, 20 U.S.C. 1232g; records described at 20 U.S.C. 1232g(a)(4)(B)(iv); and employment records held by a Covered Entity in its role as employer.
- 24. Security: Security, or security measures, encompasses all the administrative, physical, and technical safeguards in an information system (45 C.F.R. § 164.304). It relates to the extent to which information can be stored and provided with access limited to those who are authorized and have a legitimate need to use/disclose such information.
- 25. Uses and disclosures of Protected Health Information (PHI): All individually identifiable health information, (including genetic information) whether oral or recorded in any form, that relates to the past, present, or future physical or mental health or condition of a Member; the provision of health care to a Member; or the past, present, or future payment for the provision of health care to a Member (45 C.F.R. § 160.103). PHI excludes individually identifiable health information in education records covered by the Family Educational Rights and Privacy Act, as amended, 20 U.S.C. 1232g; in records described at 20 U.S.C. 1232g(a)(4)(B)(iv); in employment records held by a Covered Entity in its role as employer; and regarding a person who has been deceased for more than fifty (50) years. PHI also generally refers to demographic information, medical history, test and laboratory results, insurance information and other data that is collected by a healthcare professional to identify an individual and to determine appropriate care

IV. Policy

- 1. Human Compass MSO has adopted and maintains policies and procedures required by the Health Insurance Portability and Accountability Act (HIPAA) and the American Recovery and Reinvestment Act (ARRA) to:
 - a. Ensure that Member's health information is properly protected while allowing the flow of health information needed to provide and promote high quality healthcare
 - b. Comply with the requirements of ARRA including, but not limited to, Member requests for restrictions and accounting of disclosures
 - c. Protect the public's health and well-being
 - d. Adhere to the HIPAA General Administrative Requirements as published in the final rule on December 28, 2000, and amended on May 31, 2002, and August 14, 2002. These requirements are found in Title 45 of the Code of Federal Regulations (C.F.R.) Part 160, Part 162, and Part 164. Comply with the administrative, physical and technical safeguards of the HIPAA Security Rule, as required by the Health Information Technology for Economic and Clinical Health Act (HITECH Act) and any and all Federal regulations and interpretive guidelines promulgated thereafter
 - e. Comply with the California Department of Health Care Services (DHCS); Center for Medicare and Medicaid Services (CMS); and the HITECH Act breach reporting requirements

Human Compass MSO

- f. Provide HIPAA training to Human Compass MSO Team Members, Board of Director (BO) Members Governing Board Members and Management; Business Associates, first tier and downstream entities and vendors with access to Member PHI

V. Procedure

1. Human Compass MSO will use HIPAA definitions, as found in 45 C.F.R. §160.103, 164.402 and 164.501.
 - a. Any modifications from the Department of Health and Human Services (DHHS) to the existing definitions will be incorporated into new Human Compass MSO policy creation; any applicable existing Human Compass MSO policy will be edited/ revised accordingly.
 - b. Human Compass MSO will use the definitions in 45 C.F.R. §1640.202 in general use and in specific reference to determining if HIPAA preempts State Law.
2. Organizational Structure and Resources
 - a. The day-to-day oversight of the HIPAA Program is the direct responsibility of the Compliance Officer, who reports compliance issues and activities to Senior Management, the Chief Executive Officer, and the Board of Directors.
 - b. The Compliance Officer oversees all aspects of the Program including but not limited to:
 1. Uses and disclosures of Protected Health Information (PHI)
 2. Privacy policies and procedures, including but not limited to complaint procedures and compliance with state and federal reporting requirements
 3. Training program for Team Members, Business Associates, First tier and downstream entities
 4. Mitigation of any harmful effects caused by use or disclosure of PHI by Human Compass MSO Team Members or external associates in violation of Human Compass MSO privacy policies and procedures
 5. Maintenance of reasonable and appropriate administrative, technical, and physical safeguards to prevent intentional or unintentional use or disclosure of PHI
 - c. The Compliance Officer has ultimate responsibility for the HIPAA Program
 - d. The Human Compass MSO Board of Directors will provide oversight of the HIPAA Program
3. Uses and Disclosures
 - a. Basic Principle for Uses and Disclosures: Human Compass MSO may not use or disclose PHI, except either as the Privacy Rule permits/requires or as the Member who is the subject of the information (or the Member's personal representative) authorizes in writing.
 - b. Required Disclosures: Human Compass MSO must disclose PHI in only two (2) situations: (a) to Members (or their personal representatives) specifically when they request access to, or an accounting of disclosures

Human Compass MSO

- of, their PHI; and, (b) to a contracted government agency when it is undertaking a healthcare compliance investigation or review or enforcement action.
- c. Permitted Uses and Disclosures: Human Compass MSO is permitted, but not required, to use and disclose PHI, without a Member's authorization, for the following purposes or situations: (1) To the Member, with limited exceptions; (2) Treatment, Payment and Health Care Operations; (3) Opportunity to Agree or Object; (4) Incident to an otherwise permitted use and disclosure; (5) Limited Data Set without member specific identification for the purposes of research, public health or health care operations. Human Compass MSO may rely on professional ethics and best judgments in deciding which of these permissive uses and disclosures to make, but under no circumstance will Human Compass MSO permit the use or disclosure of PHI outside of these permissive uses without obtaining specific member authorization prior to said disclosure.
 - d. Marketing: Except for designated marketing activities that may be conducted without Member authorization according to 45 C.F.R. §164.508 (a) (3), it is the policy of Human Compass MSO to obtain the Member's authorization prior to using or disclosing PHI for marketing purposes, in compliance with HIPAA regulations, specifically 45 CFR §164.508 (a);
 - e. Minimum Necessary: Human Compass MSO will make all reasonable efforts to use, disclose and request only the minimum amount of PHI needed to accomplish the intended purpose of the use, disclosure, or request. The minimum necessary requirement does not apply in any of the following circumstances:
 - 1. Disclosure to or a request by a health care provider for treatment
 - 2. Disclosure to a Member who is the subject of the information, or the Member's personal representative
 - 3. Use or disclosure made pursuant to an authorization
 - 4. Disclosure to a contracted government agency for healthcare related complaint investigation, compliance review or enforcement
 - 5. Use or disclosure that is required by law
 - 6. Use or disclosure required for compliance with the applicable requirements of HIPAA Administrative, Data Standards and Related Requirements (45 C.F.R. Subtitle A, Subchapter C)
 - 4. Accounting of Disclosures of PHI: Upon Member request, it is the policy of Human Compass MSO to provide Members with an accounting of PHI disclosures made by Human Compass MSO within the last six (6) years (or shorter period of time if a shorter period is requested) prior to the date on which the accounting is requested.
 - 5. Privacy Practices Notice: In accordance with HIPAA 45 CFR §164.520, Human Compass MSO provides the "Notice of Privacy Practice" to all newly enrolled Medical Members as follows:
 - a. At enrollment and annually thereafter as an insert with Initial Health Assessment Notification

Human Compass MSO

- b. Within 60 days of a material change to the uses or disclosures, the Member's rights, Human Compass MSO's legal duties, or other material privacy practices stated in the Notice
 - c. Upon request by any person, including Human Compass MSO Members
- 6. Access: It is the policy of Human Compass MSO to allow Members or their legal representative to inspect and receive a copy of their PHI within the Human Compass MSO designated record set upon request, with some exceptions. Members, or their legal representatives, will be requested to submit their request in writing and to submit proof of identity for the release. The "designated record set" is a group of records maintained by Human Compass MSO that are used to make decisions about Member enrollment; provider payments; claims adjudication; and case or medical management systems.
 - a. The Privacy Rule except from the right of access the following PHI (45 C.F.R. §164.524):
 - 1. Psychotherapy notes maintained separate from other mental health records
 - 2. Information compiled in reasonable anticipation of, or for use in, civil, criminal, or administrative actions or proceedings
 - 3. Laboratory results to which the Clinical Laboratory Improvement Act (CLIA) prohibits access
 - 4. Information held by certain research laboratories
 - b. Human Compass MSO may deny access to a Member or their representative in certain specified situations, such as when a health care professional believes that access could cause harm to the Member or another. In such cases, the Member or their authorized representative are given the right to have such denials reviewed by a licensed health care professional. Human Compass MSO will provide or deny access in accordance with the reviewing official's determination.
- 7. Amendment:
 - a. Human Compass MSO Members have a right to amend their PHI in a designated record set when that information is inaccurate or incomplete (45 C.F.R., § 164.526). If an amendment is granted in whole or in part, Human Compass MSO must:
 - 1. Amend the information or the record that is the subject of the request
 - 2. Notify the Member that the amendment has been accepted
 - 3. Notify relevant persons, providers, business associates or organizations identified by either the Member or Human Compass MSO, of the amendment.
 - b. Human Compass MSO may deny an amendment based on the following instances:
 - 1. Information requested to be amended was not created by the provider

Human Compass MSO

2. Information requested to be amended is not part of the designated record set
 3. Information requested to be amended is not information that the Member has a right to access
 4. Information requested to be amended is accurate and complete
 - c. If the request is denied, Human Compass MSO will provide the Member with the basis for the denial and inform the Member of their right to submit a statement of disagreement which shall be filed, and subsequently released with, the record; and, a description of how the Member can commence a complaint to Human Compass MSO or to the Secretary of DHHS.
 - d. Human Compass MSO will amend PHI in its designated record set upon receipt of notice to amend from another covered entity.
8. Restriction Requests:
 - a. In the case that a Member requests under 45 C.F.R. § 164.522 (a)(1)(i)(A), that Human Compass MSO restrict the disclosure of his/her PHI, notwithstanding paragraph (a)(1)(ii) of such section, Human Compass MSO must comply with the requested restriction if:
 1. Except as otherwise required by law, the disclosure is to a health plan for purposes of carrying out payment or health care operations (and is not for purposes of carrying out treatment)
 2. The PHI pertains solely to a health care item or service for which the health care provider involved has been paid out of pocket in full
 - b. Members have the right to request that Human Compass MSO restrict use or disclosure of PHI to notify family members or others about the Member's general condition, location, or death.
 - c. Human Compass MSO will not agree to the restriction or denial of PHI as requested by the Member if Human Compass MSO determines that the information being restricted would impede treatment for the Member being served.
9. Confidential Communications: Human Compass MSO permits Members to request an alternative means or location for receiving communications of PHI by means other than those that Human Compass MSO typically employs.

Human Compass MSO will accommodate reasonable requests if the Member indicates that the disclosure of all or part of the PHI could endanger the Member.

Human Compass MSO will not question the Member's statement of endangerment
10. Administrative Requirements
 - a. Privacy Policies and Procedures: Human Compass MSO has developed and implemented policies and procedures that are consistent with The Privacy Rule. Privacy policies and procedures are reviewed annually and revised as changes in laws, regulations, environmental conditions, operations and/or the delegate's policies are published.
 - b. Privacy Personnel: Human Compass MSO has designated the Compliance Officer as their privacy official responsible for developing and

Human Compass MSO

implementing its privacy policies and procedures to ensure confidentiality.

- c. Compliance Department: Human Compass MSO has designated its Compliance Department as the office responsible for receiving HIPAA related complaints and providing Members and other individuals with information on Human Compass MSO HIPAA practices.
- d. Team Member Training: Training requires that all Human Compass MSO Team Members, including management, Providers and Directors demonstrate awareness and understanding of HIPAA Privacy and Security standards, as well as Privacy requirements under the HITECH Act and ARRA. Additionally, business associates, first tier and downstream entities and vendors who have access to Member PHI must document that their workforce members have been trained on these standards.
 - 1. Human Compass MSO provides training for all Team Members on its privacy and security policies and procedures, as necessary and appropriate for them to carry out their functions and report their privacy concerns.
 - 2. The Human Compass MSO “New Hire Orientation” manual is provided to every newly hired Team Member and Team Member must provide evidence of completion of HIPAA training and orientation from the manual is required prior to newly hired Team Member is exposed to PHI.
 - 3. Newly hired Human Compass MSO Team Members are required to sign a “Protected Health Information (PHI) Confidentiality Statement” at the time of their Human Compass MSO orientation process.
 - 4. On an annual basis, each Team Member is required to attend compliance training and to pass a post training test by a score of not less than 85%.
 - 5. Training for Human Compass MSO Team Members is provided when material changes have been made to the privacy and security procedures. The training is provided on the changes within a reasonable period following approval by the Compliance Officer and the Compliance Committee.
 - 6. Each time Team Members log in to the system they receive a message reminding them regarding HIPAA policies including how they can report suspected violations and or view said policies and training materials.
 - 7. The availability of a Compliance Hotline to accept anonymous privacy and/or security complaints/concerns regarding HIPAA non-compliance is included in all training sessions as well as appearing on the internal website. Human Compass MSO has a zero-tolerance policy for retaliatory action against Team Members who report HIPAA concerns.

Human Compass MSO

8. Other training materials for Team Members include, but are not limited to, periodic security updates and privacy and security reminders.
- e. Business Associate, First Tier and Downstream Entities and Vendor Training: Human Compass MSO provides HIPAA learning experiences including, but not limited to:
 1. Education which provides a formal training program that includes HIPAA content.
 2. Mailings and publications containing confidentiality reminders.
- f. Provider Training: Providers are notified of on-line training opportunities available to them by request. Additionally, reported breaches of information by a provider result in letter to the provider offering on-line training for them and/ or their staff members.
- g. Mitigation: Human Compass MSO shall mitigate, to the extent practicable, any harmful effect it learns was caused by use or disclosure of PHI by its Team Members or its business associates in violation of its privacy policies and procedures or the Privacy Rule.
- h. Data Safeguards: Human Compass MSO maintains administrative, technical and physical safeguards to prevent intentional or unintentional use or disclosure of PHI in violation of the Privacy Rule and to limit incidental use and disclosure. Policies and Procedures have been developed and implemented. However, due to the rise in unauthorized disclosures of protected patient medical records, confidentiality requirements were enhanced by state laws Assembly Bill 211 and Senate Bill 541, effective 1/1/09, with certain provisions amended by Assembly Bill 1755, effective 1/1/15. The bills make Providers accountable for unauthorized access to medical information, not just for unlawful use or disclosure. Patient Every healthcare entity must implement appropriate administrative, technical, and physical safeguards to protect the privacy of a patient's medical record information and safeguard it from unauthorized access or unlawful access, use, or disclosure. Administrative fines for violations range from \$25,000 to \$250,000.
 1. Human Compass MSO utilizes a document cross shredding service and there are securely locked shredder bins in each business area to hold confidential documents prior to shredding.
 2. Hard copy documents containing PHI are secured under lock and key during non- business hours; and all Team Members have been provided with "PHI Protectors" to be placed over any and all confidential documents that are in process at their desks.
 3. Procedures are in place to ensure faxes containing PHI are not left unattended and fax machines are in secure areas.
 4. Procedures are in place for mailing PHI only by secure methods. Disks and transportable media sent through the mail are encrypted.

Human Compass MSO

5. Human Compass MSO has a mechanism in place to encrypt and decrypt ePHI.
 6. The Human Compass MSO IT department has termination procedures in place for terminating access to PHI/ePHI when the employment of a workforce member or contractor ends or access to ePHI is inappropriate.
 7. The Human Compass MSO IT department has policies and procedures in place for electronic security from unauthorized disclosure, i.e., passwords; screen time-outs; secure E-Mail; etc. Team Member responsibilities for electronic security are included in compliance training for Team Members.
 8. The Human Compass MSO IT department has implemented technical safeguards to protect PHI.
 9. Human Compass MSO protects the privacy of individual Member PHI by de-identifying PHI when released for purposes other than treatment, payment, or healthcare operations; for use without the Member's authorization; and, for purposes other than those legally required under HIPAA to protect public safety.
 10. The Human Compass MSO Team Member Handbook addresses the policy for verbal PHI, including Team Member discussion outside the Human Compass MSO offices.
 11. Human Compass MSO has implemented a policy that addresses verifying the identity of the individual requesting PHI prior to release of the information. By administering this policy, Team Members put forth their best efforts to send PHI, in any format, to the appropriate requestor.
 12. The Operations Department has implemented physical safeguards for PHI including, but not limited to, controlled access to all areas of the buildings as detailed in their Policies and Procedures.
 13. Human Compass MSO educates its Team Members on the importance of privacy laws and the policy on privacy of medical information.
 14. Team Members are made aware that appropriate, documented action will be taken should unauthorized access occur; and any incident of unauthorized access will be reported to the Appropriate entity and to the affected patient within fifteen (15) days after detection of the breach.
 15. Team Members are made aware that PHI is not to be removed from Human Compass MSO offices except for routine business purposes.
- i. Compliance
1. The Compliance Department may conduct monthly in-house, random departmental HIPAA walkthroughs to assess Team Member compliance with the Human Compass MSO PHI privacy policy. But at a minimum an annual risk analysis will be performed.

Human Compass MSO

2. Human Compass MSO requires that business associates who may be recipients of PHI must agree, in writing, to certain mandatory contract provisions regarding the use and disclosure of PHI.
 3. Human Compass MSO monitors contracted providers and business associates for compliance with HIPAA regulations prior to contracting and annually thereafter.
- j. Incident
1. Complaints/HIPAA Non-Compliance: Human Compass MSO has a policy and procedure in place for Members, Team Members, Business Associates, or other individuals to submit complaints and/or incidents of non-compliance with HIPAA requirements to the plan and/or to the Secretary of DHHS.
 2. Retaliation and Waiver: Human Compass MSO does not retaliate against a person for exercising rights provided by the Privacy Rule, for assisting in an investigation by DHHS or another appropriate authority, or for opposing an act or practice that the person believes in good faith violates the Privacy Rule. Human Compass MSO does not require a Member to waive any right under the Privacy Rule as a condition for obtaining treatment, payment and enrollment or benefits eligibility.
- k. Documentation and Record Retention: Human Compass MSO maintains archived manuals containing privacy policies and procedures, privacy practice notices, disposition of complaints and other actions, activities, and designations that the Privacy Rule requires for a period of ten (10) years.
- l. Medical Identity Theft: Human Compass MSO includes an explanation of this fast-growing type of crime in HIPAA Team Member training programs and educates Team Members relative to ways in which to identify the types of medical identity theft and the ways in which they can safeguard confidential information.
- m. Reporting Unauthorized Access or Disclosure: Human Compass MSO only provides the following required notifications if the breach involved unsecure PHI. Unsecure PHI is PHI that has not been rendered unusable, unreadable, or indecipherable to unauthorized persons through the use of a technology or methodology specified by the Secretary in guidance.
1. Breaches of Unsecure PHI, Affecting Fewer than Five Hundred (500) Individuals: For breaches that affect fewer than five hundred (500) individuals, Human Compass MSO must provide the Secretary of the Department of Health and Human Services (DHHS) with notice annually. All notifications of breaches occurring in a calendar year must be submitted within sixty (60) days of the end of the calendar year in which the breaches occurred. This notice must be submitted electronically by following the link below and completing all information required on the breach notification form. A separate

Human Compass MSO

form must be completed for every breach that has occurred during the calendar year. Link to Form: <http://ocrnotifications.hhs.gov/>.

2. Breaches of Unsecure PHI, Affecting Five Hundred (500) or ore Individuals: If a breach affects five hundred (500) or more individuals, Human Compass MSO must provide the Secretary of DHHS with notice of the breach without unreasonable delay and in no case later than sixty (60) days from discovery of the breach. This notice must be submitted electronically by following the link below and completing all link information required on the breach notification form <http://ocrnotifications.hhs.gov/>
 - a. All security breaches that require a security breach notification to more than five hundred (500) California residents as a result of a single breach of the security system shall electronically submit a single sample copy of that security breach notification, excluding any personally identifiable information, to the Office of the Attorney General. <http://oag.ca.gov/ecrime/databreach/reporting>.
 - b. In addition to notifying the affected Members, Human Compass MSO is required to provide notice to prominent media outlets serving the State or jurisdiction. Human Compass MSO will likely provide this notification in the form of a press release to appropriate media outlets serving the affected area. Like individual notice, this media notification must be provided without unreasonable delay and in no case later than sixty (60) days following the discovery of a breach and must include the same information required for the individual notice.
3. Submission of Additional Breach Information to DHHS: If a breach notification form has been submitted to the Secretary and additional information is discovered, Human Compass MSO may submit an additional form, checking the appropriate box to signal that it is an updated submission. If, at the time of submission of the form, it is unclear how many individuals are affected by a breach. Human Compass MSO provides an estimate of the number of individuals affected. As this information becomes available, an additional breach report may be submitted as an addendum to the initial report.
4. Reporting Breaches to the Department of Health Care Services (DHCS): Human Compass MSO must also notify DHCS when a breach occurs that affects a Medi-Cal Member. Notification is provided to the DHCS Privacy Office, Information Security Office and to the Contract Manager within the following timelines:

Human Compass MSO

- a. By telephone, e-mail or fax within twenty-four (24) hours of discovery if PHI was or suspected to have been acquired by an unauthorized person.
 - b. After sending initial notice, Human Compass MSO will have seventy-two (72) hours from the date of discovery to provide DHCS with an initial Privacy Incident Report (PIR) within ten (10) calendar days of discovery of the breach a final, completed PIR will be submitted to DHCS, unless an exception has been obtained from DHCS for additional time needed to complete investigation.
5. Member Breach Notifications: The Human Compass MSO member(s) whose PHI has been breached must be notified in writing of the breach in accordance with CMS and DHHS requirements. Human Compass MSO is required to also notify the affected Member(s) in written form and must be provided without reasonable delay and in no case later than sixty (60) days following the discovery of a breach. This notification must include, to the extent possible, a brief description of the breach, a description of the types of information that were involved in the breach, the steps affected Members should take to protect themselves from potential harm, a brief description of what Human Compass MSO is doing to investigate the breach, mitigate the harm and prevent further breaches, as well as Human Compass MSO contact information.
6. Human Compass MSO Internal Breach Notification: The Human Compass MSO Compliance Officer must be notified of all unauthorized breaches within the regulatory timeline requirements.
7. Reporting a Breach to Contracted Health Plans: Breach will also be communicated to Human Compass MSO contracted Health Plans within a sixty (60) daytime frame following the discovery of a breach. This notification must include, to the extent possible, a brief description of the breach, a description of the types of information that were involved in the breach and a brief description of what Human Compass MSO is doing to investigate the breach, mitigate the harm and prevent further breaches.
 - a. Human Compass MSO HIPAA FWA Breach Compliance Incident Notifications and Reports may be submitted 24 hours a day, 7 days a week via the following:
 - i. Website: [enter website]
 - ii. Compliance incident form (can be submitted anonymously): [enter link for the anonymous incident form]
 - iii. Email: [enter Compliance email address]
 - iv. Anonymous Hotline: [enter Phone Number]
 - v. Mail: [enter mailing address]

Human Compass MSO

- vi. Compliance Officer directly: [enter the contact information for the Compliance Officer]

Human Compass MSO

Record of Changes

Version Number	Date	Revised Section	Revised/ Reviewed By	Description of Change
V1	01.01.2026	All		P&P Creation
V1	08.27.2025		Board of Directors	Review and approve original policy
V1	09.23.2026		Linette Hughes	Annual review